OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
TU DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

SecDocVault

Privacy & Security Research

Does an encrypted vault keep its promises?

Danyil Tymchuk · Artem Surszenko · Illia Stefanovskyi

Supervisor: Peter Alexander

04/09/2026

WHY THIS RESEARCH

Encrypted, and still failing its user

85%

of tested apps break at least one OWASP Mobile Top 10 category

93% / 62%

confident in their mobile defences, yet breached last year

€7.1B

cumulative GDPR fines since 2018; 443 breach reports a day

- Phones now hold passports, medical letters, bank records — often behind nothing but a lock screen
- We built SecDocVault, so we hold the source and full authorisation

LITERATURE REVIEW

Three strands, one finding

A Anonymity & fingerprinting

- Encrypted content ≠ privacy
- 24% of fingerprinting from SDKs that never declare it
- Data survives factory reset on Android 11–12

B Data protection & privacy law

- Encrypted data is still personal data
- Articles 5, 17, 25 and 32 all apply
- MEGA broken at protocol, not cipher

C Applied cryptography

- Correctness lives in the compiled outcome, not the algorithm
- Supply chain: Thompson, Codecov, NIST
- Harvest now, decrypt later

The common finding: the security of a document vault is decided far less by the choice of primitives than by the configuration around them — all three strands reach this independently.

THE GAP

What prior work leaves open

Prior research

- Corpus-scale surveys
- Black-box, closed source
- Server side only
- The law described, never measured

This project

- One real application, source known
- Client, device and backend in scope
- The law turned into pass/fail tests
- All three lenses on one artefact

Nobody has run all three lenses over one vault they fully understand.

What we set out to falsify

Hypothesis

Correct cryptographic primitives can still fail their guarantees — because the weaknesses can sit in configuration, metadata and identifiability.

RQ1 Can a user be identified despite encryption? Is deletion real?

RQ2 Which data-protection duties does encryption not satisfy?

RQ3 What makes a source of cryptographic primitives trustworthy?

RQ4 Where is the promise-behaviour gap, and what closes it?

METHODOLOGY

Three phases, four methods, published checklists

01 Documentary

Literature sets the criteria

02 Development

Extend the app, unit-test, freeze v0.1.3

03 Assessment

Static, dynamic and forensic testing

Methods

- Implementation analysis
- STRIDE and LINDDUN threat models
- Dynamic and forensic testing on device
- GDPR and HIPAA mapped to tests

Frameworks & environment

- OWASP MASVS v2 and MASTG
- PTES lifecycle, CVSS v3.1 scoring
- v0.1.3 on Android 15 and 13, unrooted
- Synthetic documents only

THE ARTEFACT

What it is, and where the keys live

Architecture

- React Native, Android
- Firebase backend — no dedicated app server
- Security rules and authentication are the only access controls

Cryptographic design

- AES-256-GCM per file, fresh IV
- PBKDF2-SHA256, 100,000 it. passphrase derivation
- RSA-2048-OAEP for share wraps

Three key wraps, five places data rests

Device wrap

Located in Android Key Store

Recovery wrap

Sealed under a recovery passphrase

Share wrap

Sealed to the recipient's public key

Keys rest in: Keychain · AsyncStorage · filesystem · Firestore · Cloud Storage

IMPLEMENTATION

Nine promises, made falsifiable

1 Confidentiality

Bytes unreadable without the key

2 Integrity

Tampering is detected

3 Local-only

Guest mode sends transmits nothing

4 Access control

Owner and grant holders only

5 Revocation

Revoked means no access

6 Deletion

Deleted is unrecoverable

7 Recovery

Backend holds no bare key

8 Redaction

Redacted exports hide values

9 Non-identifiability

No identifying or linking signals

TESTING

The programme at a glance

Functional

Jest unit suite plus manual integration testing

Non-functional

Performance to the 10 MB ceiling; cryptographic validation

TA series

Eleven tests: fingerprinting, linkability, remanence

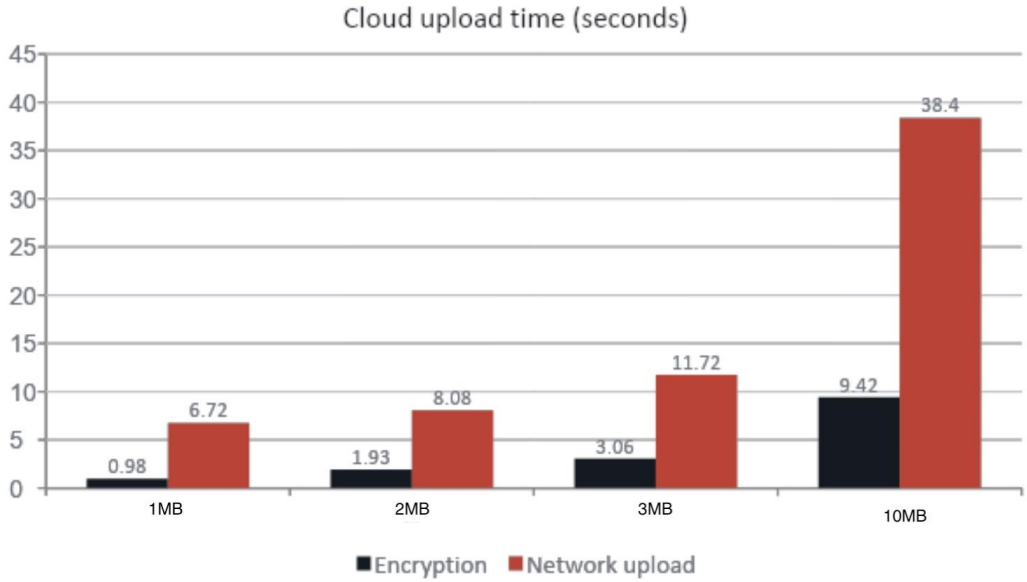
MASVS + data protection

Eight control groups; five article-mapped tests

33	privacy findings
12	rated High
5	MASVS findings
0	clean passes

TESTING — PERFORMANCE

Crypto is not the bottleneck



- One second per megabyte, linear to the ceiling
- Network dominates — 38 of 48 seconds at 10 MB
- CyberChef confirms the primitives are as claimed

Takeaway: optimise stored size, not the cryptography.

TESTING — TA REGISTER

Eleven procedures, eleven verdicts

Test	Verdict	Max severity
TA-01 Identifier and permission surface	FAIL	High (8.8)
TA-02 Dependency and SDK provenance	FAIL	Medium
TA-03 Guest-mode network silence	FAIL	High
TA-04 Linkability and TLS fingerprint	FAIL	Medium (3.7)
TA-05 Account-existence disclosure	FAIL	High (6.5)
TA-06 Persistence across reinstall	PASS / FAIL	Medium (4.6)
TA-07 Metadata survival	FAIL	High (6.1)
TA-08 Cache and temp artefacts	FAIL	High (7.5)
TA-09 Device remanence after delete	FAIL	High (6.2)
TA-10 Backend remanence after delete	FAIL	High (4.3)
TA-11 Key-material remanence	FAIL	High (6.2)

No test returned a clean pass. 33 findings: 12 High, 16 Medium, 4 Low, 1 Informational.

TESTING — FINDINGS I

How a user is exposed

8.8	Release build signed with a public debug keystore
High	Telemetry fires in guest mode — the local-only mode
Med	Nine of ten permissions arrive from dependencies
6.5	The whole user directory dumped in one request
3.7	Upload sizes link sessions with no identifier

Passes

- No advertising ID, MAC, IMEI or serial
- No analytics SDK on the classpath
- No identifier survives reinstall
- TLS fingerprint identifies the stack, not the app

TESTING — FINDINGS II

What outlives the promise

Metadata survives

- EXIF, GPS and camera serial survive export
- Stripping is an accident of re-encoding
- Censor mode ignores export permission

Deletion leaves residue

- Plaintext cache never cleaned — 15 days observed
- A cached token bypasses the rules entirely
- Keychain key orphaned; bucket keeps objects 7 days

For seven days the backend holds the ciphertext without its key, and the device holds the key without its ciphertext.

Article 17 fails forensically and legally at once.

TESTING — OWASP MASVS

Primitives pass, configuration fails

MASVS group	Verdict	Why
STORAGE	PARTIAL	Metadata and salt in plaintext
CRYPTO	PARTIAL	Legacy AES-CBC path reachable
AUTH	PARTIAL	Sign-in link over an unverified scheme
NETWORK	PARTIAL	No certificate pinning
PLATFORM	PARTIAL	Browsable deep link
CODE	FAIL	Debug keystore in version control
RESILIENCE	FAIL	No anti-tamper or integrity checks
PRIVACY	FAIL	Excess collection, inherited tracking

Everything touching the cipher passes. Everything failing is configuration.

TESTING — DATA PROTECTION

Where encryption stops being enough

Obligation	Verdict
Art. 5 — minimisation	FAIL
Art. 25 — privacy by default	PARTIAL
Art. 32 — security of processing	PARTIAL
Art. 17 — right to erasure	FAIL
Art. 9 / HIPAA — health data	FAIL

Zero-knowledge

Holds for content.

Fails for names, descriptions and filenames — all reach Firestore in cleartext.

A document named "HIV results 2026" discloses its subject without touching the ciphertext.

COMPARISON WITH RELATED RESEARCH

Where SecDocVault sits

Zhang et al. (2017)

18 vault apps, 220M downloads — six encrypted nothing

Ruffin et al. (2022)

20 vaults — most failed the weakest adversary

Egele et al. (2013)

88% of apps misused a cryptographic primitive

Firebase at scale

4,282 leaking apps from 515,735 scanned

Our position

- The literature finds cryptography weak — ours is correct
- So the failures can only sit in configuration and lifecycle
- Source-known testing names the rule, not just the symptom

WHAT WE ACHIEVED

The nine claims, scored

1 Confidentiality — PARTIAL	2 Integrity — PARTIAL	3 Local-only — FAIL
4 Access control — PARTIAL	5 Revocation — PARTIAL	6 Deletion — FAIL
7 Recovery — PARTIAL	8 Redaction — FAIL	9 Identifiability — FAIL

Hypothesis confirmed — every finding sits in configuration, metadata or lifecycle. None attacks the cipher.

RECOMMENDATIONS

In order of severity

1. **Fix build and distribution integrity**
2. **Scope the Firebase rules to the operation**
3. **Cut the transitive telemetry**
4. **Encrypt metadata, use opaque identifiers**
5. **Make deletion cryptographic at every layer**
6. **Strip metadata at ingestion, pad uploads**

Future work

Re-test the fixed build · extend to iOS and rooted forensics · privacy regressions in CI · post-quantum readiness

Correct cryptography is necessary,
but nowhere near sufficient.

Thank you! Questions?!

Danyil Tymchuk · Artem Surszenko · Illia Stefanovskyi | github.com/DanyilT/SecDocVault